Segurança de Dados

MCTA023-17

Programação Segura - parte 2

Injeção de código, XXS

Profª Denise Goya

Roteiro

- Segurança no Software e introdução a Programação Segura:
  - Injeção de Código
  - Cross-site Scripting

Injeção de Códigos

Injeção de Código e Validação de Entrada

- Injeção de código ocorre quando um invasor engana o programa a executar o seu código, através de elaboração meticulosa da **entrada** de dados que **mistura dados e código**
- Essas entradas possuem caracteres especiais que disparam uma mudança de contexto entre interpretação de dados e de código
- O invasor deseja injetar **metacaracteres** através de alguma codificação ou manipulação, de maneira que os dados de entrada acabam sendo interpretados como código

Metacaractere aspas simples ’ no SQL

- Aspas simples (’) são delimitadores de sequências de caracteres em consultas SQL
- Porém, aspas simples também podem fazer parte de **dados** como:
  - Pingo d’ água (para nome de empresa, p.ex)
  - O’ Reilly (nome de editora, ou sobrenome)
- Exemplo de instrução SQL:
  - Update Empresas SET Name = ‘Pingo d’ água’
    - É uma instrução inválida, pois o primeiro ’ encerra
    - Ambientes mais antigos não previnem esse problema

Metacaractere aspas simples ’ no SQL

- E se um usuário mal intencionado digitar, num formulário, no **campo nome da empresa**:

Pingo d’ ; Update Admins SET
Name=‘gubb’, Privilege=‘Administrator’

Caixa de texto

- a instrução SQL equivalente:
- Update Empresas SET Name = ‘Pingo d’ ; Update Admins SET Name=‘gubb’, Privilege=‘Administrator’
- o mal intencionado conseguirá criar uma nova conta com privilégios de administrador

SQL Injection

- Esse tipo de ataque é conhecido por injeção de SQL, ou "SQL Injection"

- Pode comprometer aplicações com acesso a banco de dados, via Web ou não.
  - Ex: PHP

SQL Injection: outro exemplo

- Código sem proteção:

```
string sql = "SELECT userid, firstname, lastname FROM users WHERE
username = '" + txtUsername.Text +  "' and password = '" +
txtPassword.Text + "'";
```

- Tentativa de injeção:

  inserir no campo de username: 'OR 1=1 --

  - instrução SQL obtida:

```
SELECT userid, firstname, lastname  FROM users WHERE username = '' OR  1=1  --
```

  - é obtida a lista de todos usuários registrados

Metacaracteres e Escape

- Contornando o problema:
  - Filtrar corretamente: somente caracteres válidos devem ser passados
- Uso de caracteres de **escape**: barra invertida, por exemplo, em SQL:
  - Update Empresas SET Name = ‘Pingo d\’ Update Admins SET Name= \‘gubb\’, Privilege= \‘Administrator’

Metacaracteres e Parametrização

- Gerenciadores de bancos de dados ou bibliotecas de acesso a BDs oferecem funções prontas que inserem corretamente esses caracteres de escape (parametrização de queries)

- exemplo:

```
string sql = "SELECT userid, first name, lastname FROM users WHERE
    username = @username and password =  @password";
```

Cross-site Scripting

Vulnerabilidade Cross-site Scripting (XSS)

- Vulnerabilidades de cross-site scripting permitem a introdução de **conteúdo malicioso** (scripts) **em um site**, que então é executado para outros usuários (clientes)
- Scripts maliciosos são executados nos clientes que confiam naquele site
- Problema que afeta potencialmente todas as linguagens de script executadas no cliente
  - JavaScript, Java, ActiveX, ActionScript (Flash), etc

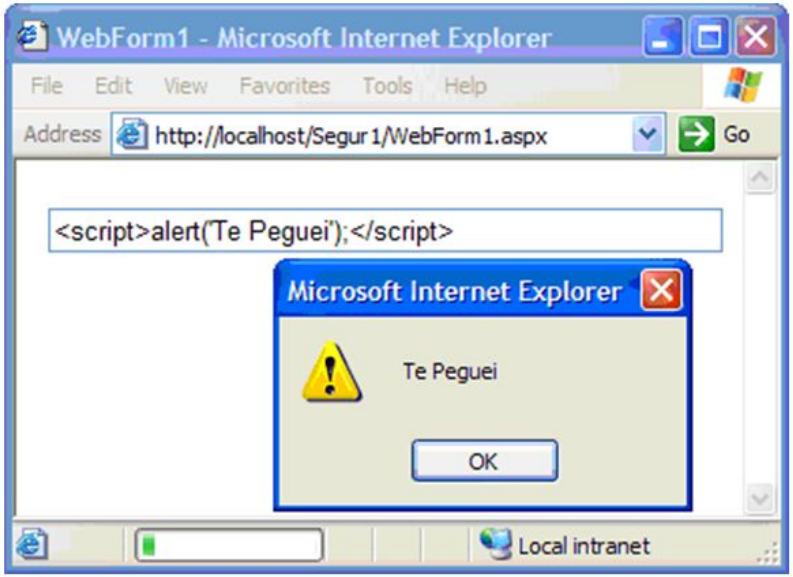
Cross-site Scripting

- Ataques cross-site scripting (XSS ou CSSI) ocorrem em sites em que um usuário escreve textos para outros lerem
  - Ex: blogs, fóruns, etc
- Um usuário digita, por exemplo, um **script** numa **caixa de texto**:

“<script>alert('Te Peguei');</script>”

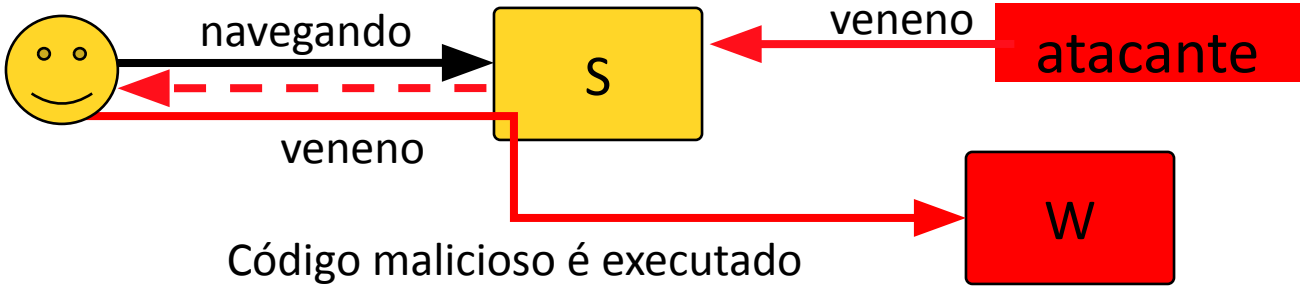
Cross-site Scripting

- Se o site não codifica o texto antes de exibi-lo, tem-se:



XSS: Por que esse nome?

- Você pensa que está interagindo com S
- Site S foi envenenado pelo atacante
- O “veneno” (ex.: JavaScript) é enviado para você junto com conteúdo legítimo e é executado
  - Pode explorar vulnerabilidades no browser ou contactar o site W e roubar cookies, senhas, etc



Próximas Aulas

Terça, dia 24/março

- Apresentações de trabalhos (30 minutos por grupo, máximo 40):
  - Criptografia pós-quântica
  - Firewall

  } Plano de Ensino atualizado no Moodle
- Submeter **slides** até o dia anterior à apresentação
  - Atividade específica no Moodle

Quinta, dia 26/março:

- Laboratório com programação segura

Submissão no Moodle

Trabalho em Equipes

Entrega-2: Texto completo (apenas um integrante submete PDF até 24/mar: BLOCO 1 - grupos que apresentam entre 24/mar e 02/abril)

Vencimento: terça-feira, 24 mar. 2026, 23:59

Disponível se: Você faz parte de um grupo em **Bloco1**

Entrega-2: Texto completo (apenas um integrante submete PDF até 07/abr: BLOCO 2 - grupos que apresentam entre 07/abril e 16/abril)

Vencimento: terça-feira, 7 abr. 2026, 23:59

Entrega-3: Slides para apresentação (prazo: antes do seminário)

Marcar

Submissão no Moodle

Trabalho em Equipes

Entrega-2: Texto completo (apenas um integrante submete PDF até 24/mar: BLOCO 1 - grupos que apresentam entre 24/mar e 02/abril)

Vencimento: terça-feira, 24 mar. 2026, 23:59

Disponível se: Você faz parte de um g

Entrega-2: Texto completo (apenas um

que apresentam entre 07/abril e 16/ab

Vencimento: terça-feira, 7 abr. 2026, 23:59

Entrega-3: Slides para apresentação (p

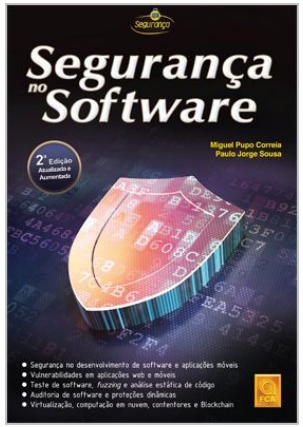
Segurança de Dados - Temas e Equipes dos Trabalhos

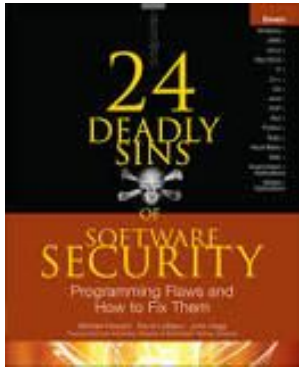
G1	**Software malicioso (G1)**	**link dos slides:**
	Tópicos obrigatórios:	
	Tipos e Funcionamento	https://xxxx
	Técnicas de Detecção e Defesas (estáticas e dinâmicas)	
	Referências principais:	**link do texto final:**
	Aslan, Ö. A. and Samet, R. "A Comprehensive Review on Malware Detection Approaches," in IEEE Access, vol. 8, pp. 6249-6271, 2020, doi: 10.1109/ACCESS.2019.2963724.	
	W. Stallings and L. Brown, Computer Security: Principles and Practice, 4ed ;Pearson Education, 2018.	
G2	**Ataques de negação de serviço (G2)**	**link dos slides:**
	Tópicos obrigatórios:	

Estudo Individual

Leitura Recomendada

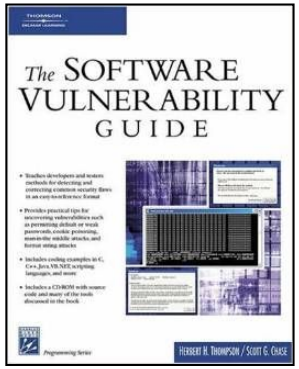
- CORREIA, M.P.; SOUSA, P.J.: "**Segurança no Software**" 2ª ed., FCA, 2017.
- HOWARD, M.; LEBLANC, D.; VIEGA, J.: "**24 Deadly Sins of Software Security: Programming Flaws and How to Fix Them**" McGraw-Hill Ed, 2009

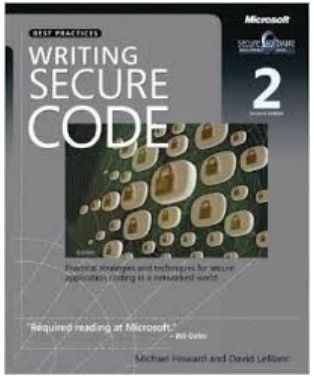




Leitura Recomendada

- THOMPSON, H.; CHASE, SCOTT G.: "**The Software Vulnerability Guide**" Charles River Media, 2005
- HOWARD, M.; LEBLANC, D.: "Writing Secure Code" Microsoft Press, 2a edição, 2002.
- WEELER, D.: "Secure Programming for Linux and Unix HOWTO – Creating Secure Software". Ebook disponível em http://www.dwheeler.com/secure-programs/





Questões de Autoavaliação

(não precisa entregar)

Exercício

Dos problemas estudados, cite quais podem afetar os requisitos de segurança abaixo e justifique:

- confidencialidade
- integridade
- disponibilidade